

## Oversight of Notification of Breach of Data Protection Security

Date: 31-08-2023

Decision

Public Authorities

No Criticism

Oversight / Self-initiated Case

Notification of Breach of Data Protection Security

Unintentional Disclosure

The Data Protection Agency has conducted 16 planned inspections focusing on municipalities' and banks' handling of breaches of data protection security. The Data Protection Agency found reason to express criticism in two cases.

Journal Number: 2021-423-0245.

Hjørring Municipality was among the public authorities that the Data Protection Agency selected for oversight in the spring of 2021 under the General Data Protection Regulation [1] and the Data Protection Act [2].

The Data Protection Agency's oversight was a written inspection that focused on whether Hjørring Municipality reports and documents breaches of data protection security in accordance with Article 33, paragraph 1, and Article 33, paragraph 5 of the General Data Protection Regulation, including the municipality's processes for handling and recording breaches of data protection security. The oversight was based on an assessment of samples among unreported breaches as well as information about guidelines, procedures, and training activities, etc.

The oversight was announced to Hjørring Municipality by letter dated June 21, 2021, and the municipality was simultaneously requested to answer a number of questions. The Data Protection Agency informed about the background for the oversight, stating that a review of the oversight cases regarding notifications of breaches of data protection security revealed that Hjørring Municipality had reported significantly fewer breaches of data protection security per inhabitant in the municipality than other municipalities in Denmark.

By letter dated July 20, 2021, Hjørring Municipality sent a statement in which the municipality responded to the Data Protection Agency's questions. Hjørring Municipality's response was also accompanied by a number of documents, including guidelines, process descriptions, and teaching materials that the municipality uses to comply with Article 33 of the General Data Protection Regulation.

### Summary

In the summer and autumn of 2021, the Data Protection Agency initiated written oversight of the handling of breaches of data protection security by eight larger municipalities and eight larger banks. The inspections were organized such that the municipalities and banks were divided into two groups – those that had reported the most and the fewest breaches in relation to the municipality's population and the number of employees in the bank.

"One of the new things that came with GDPR over five years ago was that data controllers, as a general rule, must report all breaches of data protection security to the Data Protection Agency within 72 hours, and they must also internally document all breaches of data protection security, regardless of whether they need to be reported to the Data Protection Agency or not. Furthermore, there has been an increased focus on what companies and authorities need to consider when customers' or citizens' information is mishandled by mistake," says Vibeke Dyssemark Thomsen, Chief Consultant at the Data Protection Agency, and continues: "This can, for example, lead to the need to implement new or additional security measures to reduce the risk of further breaches. Therefore, we have now conducted a service review of the area, where we have looked at the procedures and taken some samples. The conclusion is, broadly speaking, that the 16 selected municipalities and banks seem to have the right focus on complying with the rules."

### Group with the Most Reported Breaches

For the group with the most reported breaches, the inspections focused, among other things, on

whether the municipalities and banks had taken appropriate security measures to reduce the number of breaches of data protection security, where there had been unauthorized disclosure of personal data in connection with sending information to, among others, citizens, authorities, etc., including in relation to citizens with name and address protection and financial information.

Compliance with the rules on appropriate processing security will normally entail that:

The data controller must ensure that information about data subjects, including particularly confidential and sensitive personal data, does not come to the knowledge of unauthorized persons. In this context, the data controller must ensure that all employees in the organization are, to the necessary extent, familiar with any internal procedures for handling personal data, including in relation to sending personal data to, among others, citizens, authorities, etc. Procedures, guidelines, workflows, technical security measures, etc. are continuously updated or introduced, including as a result of identified breaches of data protection security.

The Data Protection Agency found on the basis of the available information that all the data controllers had taken appropriate security measures. In its assessment, the Data Protection Agency emphasized that:

Procedures, etc. had been developed and activities had been carried out to educate employees in data protection, including to ensure that they are aware that there is no unintentional disclosure of personal data to an incorrect recipient.

They have considered and continuously implemented both technical and organizational measures following past breaches of data protection security to avoid similar breaches.

There is a strong focus on avoiding unintentional disclosure of confidential information, which is supported both by business processes, ongoing guidance, etc., and systematic measures, etc.

#### **\*\*Group with the Fewest Reported Breaches\*\***

For the group with the fewest reported breaches, the inspections focused on whether the municipalities and banks report and document breaches of personal data security in accordance with the requirements of the General Data Protection Regulation (GDPR), including their processes for handling and recording breaches of personal data security.

The Data Protection Authority stated in these cases that it is the Authority's opinion that compliance with the rules that breaches of personal data security must, as a general rule, be reported to the Data Protection Authority within 72 hours implies that:

1. The data controller must establish appropriate procedures and guidelines to ensure that breaches are detected and handled correctly.
2. In this context, the data controller must ensure that all employees in the organization are adequately familiar with internal procedures for handling breaches of personal data security, and that relevant employees can identify, manage, and assess breaches of personal data security.

The Data Protection Authority found that all data controllers, overall, have adopted appropriate procedures and guidelines, etc., and have implemented appropriate training activities that can support compliance with the requirements of the GDPR regarding the reporting of breaches of personal data security. Thus, they can ensure that breaches of personal data security are captured within the organization so that these can be assessed to determine whether the breach should be reported to the Data Protection Authority, as well as to document the breaches, including, among other things, the reasons for not reporting them to the Data Protection Authority.

However, the Data Protection Authority noted in relation to all inspections that the Authority had not had the opportunity, as part of the inspection, to specifically assess whether all relevant employees have completed the relevant training activities, and that the Authority is not familiar with the full content of the training materials, including the content of, for example, ongoing awareness initiatives.

Furthermore, the Data Protection Authority stated that the rule requiring the data controller to document all breaches of personal data security, including the actual circumstances of the breach, its effects, and the remedial measures taken, among other things, must ensure that the Data Protection Authority can verify that the provision regarding the reporting of breaches of personal data security has been complied with. Therefore, data controllers should document their reasons for all significant

decisions made as a result of the breach. This is particularly relevant if the data controller, after assessing the breach, concludes that it does not need to be reported to the Data Protection Authority. The documentation should, in relation to this decision, include a detailed explanation of why the data controller believes that the breach is unlikely to result in a risk to the rights and freedoms of individuals.

#### **\*\*Criticism in Two Cases\*\***

As mentioned, there has been expressed criticism in two of the cases – specifically regarding two municipalities that did not document all breaches of personal data security.

In one case, the Data Protection Authority expressed serious criticism of Roskilde Municipality for not documenting how many breaches of personal data security the municipality has identified during the period from May 25, 2018, to September 2019, and that the municipality cannot document whether the recorded security incidents since September 2019 constitute actual breaches of personal data security.

In the other case, the Data Protection Authority criticized Frederikshavn Municipality for not documenting how many breaches of personal data security the municipality identified in 2018. The Data Protection Authority notes that the list of breaches – in addition to serving as documentation for the Data Protection Authority – should also be used by the data controller to, among other things, gain an overview of what types of breaches typically occur in the organization, and based on that, consider whether there is a need to implement new or supplementary measures to avoid or further reduce the risk of additional breaches. It is also evident from the received consultation responses that several of the data controllers actively use the lists for this purpose.

#### **\*\*1. Decision\*\***

After reviewing the submitted material, the Data Protection Authority finds reason to conclude that Hjørring Municipality has, overall, adopted appropriate procedures and guidelines and has implemented appropriate training activities to correctly capture and handle breaches of personal data security, cf. Article 33 of the General Data Protection Regulation.

Below follows a detailed review of the information that has emerged in connection with the inspection, and a justification for the Data Protection Authority's decision.

#### **\*\*2. Justification for the Data Protection Authority's Decision\*\***

##### **\*\*2.1. Relevant Legal Provisions\*\***

A breach of personal data security is defined in Article 4, No. 12 of the General Data Protection Regulation as a breach of security that leads to accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to personal data that has been transmitted, stored, or otherwise processed.

It follows from Article 33, Paragraph 1 of the General Data Protection Regulation that in the event of a breach of personal data security, the data controller must without undue delay and...

measures and procedures to ensure compliance with the requirements of the General Data Protection Regulation (GDPR) regarding the reporting and documentation of personal data breaches.

##### **2.2. Assessment of Non-Reported Breaches**

Hjørring Municipality has, at the request of the Data Protection Authority, provided an account of the first three personal data breaches that occurred in 2021, which the municipality failed to report to the Data Protection Authority. The first incident involved an internal email regarding assistive devices that mistakenly included the names of a mother and a child and was sent to the entire department instead of just to the employee who was supposed to receive the email. Employees were instructed to delete the email from their inbox and deleted items. The second incident involved an unencrypted email sent to the wrong external recipient. However, the email only contained personal data in the form of the sender's name. The third incident involved a printing solution that, in one case, attached files to the wrong user. This involved a dialogue wheel containing the name of a child, which was sent to an employee in another institution in the municipality. The recipient confirmed that the material had been deleted and shredded.

The Data Protection Authority finds no basis to override the municipality's assessment that the three

incidents can be characterized as breaches of personal data security, according to Article 4, No. 12 of the Data Protection Regulation, but that these are not subject to the obligation to report.

The Data Protection Authority thus finds no basis to override the assessment that it must be deemed unlikely that the respective breaches pose a risk to the rights and freedoms of natural persons, according to Article 33, paragraph 1.

### 2.3. Documentation, Procedures, and Employee Training

Hjørring Municipality has stated in its statement of July 20, 2021, that since May 25, 2018, a total of 113 breaches of personal data security have been recorded in the municipality. Furthermore, it appears from the statement of June 20, 2021, and the attached documents, that Hjørring Municipality has established procedures for how and where breaches of personal data security should be reported internally in the municipality, whom employees can contact with questions about breaches, who is responsible for receiving, handling, and assessing breaches, as well as for reporting to the Data Protection Authority. It is also stated that internal documentation of breaches is carried out, including the justification for why breaches have not been reported to the Data Protection Authority.

Additionally, it is noted that Hjørring Municipality has developed guidelines and conducted a number of activities aimed at educating employees in data protection, including enabling them to identify and potentially handle breaches of personal data security.

Hjørring Municipality has also explained the criteria that are included in the municipality's assessment of whether a breach of personal data security should be reported to the Data Protection Authority.

Based on the submitted material, including information about the non-reported breaches from 2021, the Data Protection Authority's immediate assessment is that Hjørring Municipality has generally adopted appropriate measures and procedures to ensure compliance with the requirements of the General Data Protection Regulation (GDPR) regarding the reporting and documentation of personal data breaches.

procedures and guidelines, etc., and has conducted appropriate training activities that can support compliance with the requirements of Article 33 of the Data Protection Regulation, and thereby ensure that breaches of personal data security are detected within the organization, so that these can be assessed to determine whether the breach should be reported to the Data Protection Authority, as well as allowing for documentation of the breaches, including, among other things, the justification for not reporting them to the Data Protection Authority.

It is noted that the Data Protection Authority has not had the opportunity, as part of its supervision, to take a specific position on whether all relevant employees have completed the relevant training activities, and that the Authority is not familiar with the full content of the training material, including the content of, for example, ongoing awareness initiatives.

[1] Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons in relation to the processing of personal data and on the free movement of such data and repealing Directive 95/46/EC (General Data Protection Regulation)

[2] Act No. 502 of 23 May 2018 on supplementary provisions to the regulation on the protection of natural persons in relation to the processing of personal data and on the free movement of such data. (Data Protection Act)